# Vulnerability Assessment Report

## AuSecurity Security Assessment 2026-10-06

**AuSecurity**
63 Paddington St
Paddington NSW 2021, Australia

**Flinders University**
Sturt Road, Bedford Park SA 5042

October 6, 2026

Report Version: 1.0

*CONFIDENTIAL*

# Table of Contents

List of Figures ..... 4

1 Document Control ..... 5

1.1 Team ..... 5

1.2 List of Changes ..... 5

2 Executive Summary ..... 6

2.1 Overview ..... 6

2.2 Identified Vulnerabilities ..... 6

3 Methodology ..... 8

3.1 Objective ..... 8

3.2 Scope ..... 8

3.3 User Accounts and Permissions ..... 8

4 Findings ..... 9

C1: Default administrator credentials on admin login ..... 9

C2: osTicket installation wizard exposed to unauthenticated users ..... 10

H1: Admin dashboard accessible without authentication (client data exposure) ..... 11

M1: Admin panel and full site served over plain HTTP on port 8080 ..... 12

M2: DOM-based cross-site scripting via "name" parameter (success page) .. 13

M3: Missing security response headers ..... 14

M4: WordPress uploads directory listing enabled ..... 15

M5: WordPress username enumeration ..... 16

M6: osTicket session cookie missing HttpOnly flag ..... 17

M7: Self-signed TLS certificate on main site ..... 18

I1: Contact API returns unhandled server error for unexpected routing field ..... 19

I2: Technology and version information disclosure ..... 20

I3: WordPress XML-RPC enabled ..... 21

I4: WordPress version and readme disclosure ..... 22

5 Disclaimer ..... 23

A Appendix ..... 24

A.1 Static Appendix Section ..... 24

A.2 Assessment Methodology ..... 24

A.3 Coverage Summary ..... 24

A.4 Limitations ..... 24

# List of Figures

Figure 1 - Distribution of identified vulnerabilities ..... 7

# 1 Document Control

## 1.1 Team

| Contact | Details | Role |
|---|---|---|
| ClawSec | Autonomous agent | Pentester |

## 1.2 List of Changes

| Version | Description | Date |
|---|---|---|
| 1.0 | Initial report | Oct 6, 2026 |

# 2 Executive Summary

## 2.1 Overview

AuSecurity's public-facing infrastructure contains several serious security weaknesses that require immediate attention.

The most urgent issue is that the main website's administrator login accepts well-known default credentials (admin / admin). This means anyone on the internet can sign in as a full administrator and take complete control of the management interface. Making matters worse, the administrator dashboard is served to visitors without any login, and it exposes business information such as client contact details and revenue figures.

A separate helpdesk subdomain (ticket.ausecurity.best) has been left in its installation-wizard state, so an outsider could complete the setup themselves and take over the ticketing system.

Other issues include a cross-site scripting flaw on the site's success page, excessive disclosure of software versions and server identity, weak security headers, and a self-signed TLS certificate that browsers cannot trust.

Taken together, these weaknesses allow an unauthenticated attacker to gain administrative control of the platform and access sensitive business and client data. We recommend immediate remediation, starting with the administrator credential, the exposed dashboard, and the osTicket installer. The Findings section of this report provides detailed technical descriptions and step-by-step remediation guidance for each issue.

## 2.2 Identified Vulnerabilities

| # | CVSS | Description | Page |
|---|---|---|---|
| C1 | 9.8 | Default administrator credentials on admin login | 9 |
| C2 | 9.8 | osTicket installation wizard exposed to unauthenticated users | 10 |
| H1 | 7.5 | Admin dashboard accessible without authentication (client data exposure) | 11 |
| M1 | 6.5 | Admin panel and full site served over plain HTTP on port 8080 | 12 |
| M2 | 6.1 | DOM-based cross-site scripting via "name" parameter (success page) | 13 |
| M3 | 5.4 | Missing security response headers | 14 |
| M4 | 5.3 | WordPress uploads directory listing enabled | 15 |
| M5 | 5.3 | WordPress username enumeration | 16 |
| M6 | 4.3 | osTicket session cookie missing HttpOnly flag | 17 |
| M7 | 4.2 | Self-signed TLS certificate on main site | 18 |
| I1 | 0.0 | Contact API returns unhandled server error for unexpected routing field | 19 |
| I2 | 0.0 | Technology and version information disclosure | 20 |
| I3 | 0.0 | WordPress XML-RPC enabled | 21 |

| # | CVSS | Description | Page |
|---|---|---|---|
| I4 | 0.0 | WordPress version and readme disclosure | 22 |

## Vulnerability Overview

In the course of this penetration test **2 Critical**, **1 High**, **7 Medium** and **4 Info** vulnerabilities were identified:

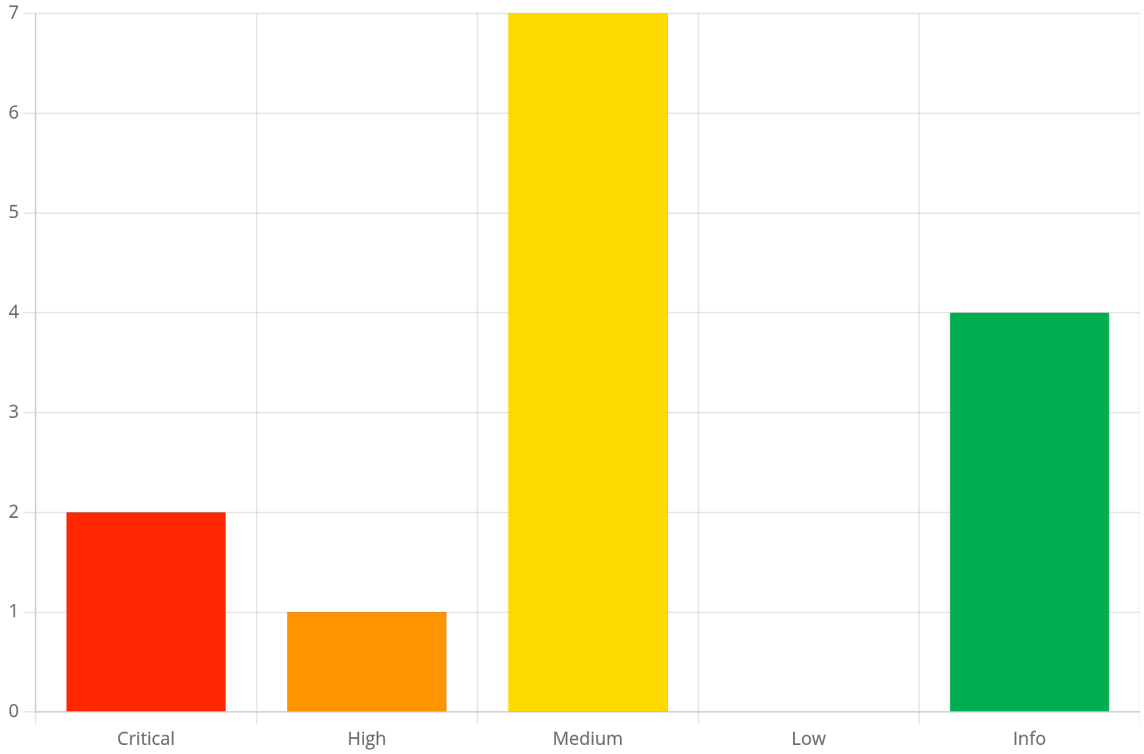



**Figure 1 - Distribution of identified vulnerabilities**

# 3 Methodology

This entire vulnerability assessment process was completed using agentic AI and existing LLM models. The purpose of such assessments is to automatically

## 3.1 Objective

The entire objective of this research is to evaluate the effectiveness of autonomously evaluate security posture for any business available on Google Map without the needs of technical guidance to determine how feasiable, seamless and cost-affective such approach is.

## 3.2 Scope

AuSecurity provides GRC consulting and penetration testing services across Australia. This assessment covered the full web application and infrastructure attack surface of the following three in-scope hosts, all hosted on OVH Singapore infrastructure:

| System | Address | Description |
|---|---|---|
| ausecurity.best / www.ausecurity.best | 51.79.166.148 | nginx static site + FastAPI backend under /api |
| blog.ausecurity.best | 51.79.167.208 | Apache 2.4.68 + WordPress |
| ticket.ausecurity.best | 51.79.166.209 | nginx + PHP 8.2.33 osTicket v1.18.4 |

The following were explicitly excluded from scope: third-party and hosting-provider infrastructure (OVH), registrar nameservers, Google Fonts/W3C assets, and non-owned parked or squatted sibling domains (ausecurity.com/.net/.org/.io/.co/.com.au/.au).

## 3.3 User Accounts and Permissions

No user accounts or credentials were provided for this engagement. All testing was performed unauthenticated (black-box).

# 4 Findings

| C1: Default administrator credentials on admin login | |
|---|---|
| Score | 9.8 (Critical) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Target | https://ausecurity.best/ (API /api/auth/login, admin panel) |
| References | https://cwe.mitre.org/data/definitions/798.html |

## Overview

The administrative login of the AuSecurity web application accepts well-known default credentials (admin / admin). Anyone who can reach the site can sign in as administrator.

## Details

A POST to /api/auth/login with {"username":"admin","password":"admin"} returns HTTP 200 and {"success":true}, and issues a signed "admin_token" session cookie (HttpOnly, Max-Age 3600). The login endpoint is also reachable over plain HTTP on port 8080. This grants an unauthenticated attacker full administrative access to the management interface, from which they could view and manipulate client data and the application.

## Recommendation

Immediately rotate the administrator password to a strong unique value, enforce account lockout/rate limiting on the login endpoint, disable the plain-HTTP port (8080), and require multi-factor authentication for administrative accounts.

| C2: osTicket installation wizard exposed to unauthenticated users | |
|---|---|
| Score | 9.8 (Critical) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H |
| Target | https://ticket.ausecurity.best/ (51.79.166.209) |
| References | https://docs.osticket.com/en/latest/Getting%20Started/Installation.html |

## Overview

The osTicket helpdesk (v1.18.4) has not been configured and exposes its full installation wizard to anonymous users, including the database-configuration step.

## Details

The root path and the staff control panel (/scp/login.php) both redirect (302) to /setup/install.php. The installer ("osTicket v1.18.4") is reachable unauthenticated and walks through prerequisite and database configuration. A remote attacker can complete the installation themselves (binding the application to a database they control or to the internal database if reachable), effectively taking over the ticketing system. The deployment has been left in its pre-installation state.

## Recommendation

Complete or remove the installation immediately and delete the /setup/ directory from the web root. Place the helpdesk behind the intended access controls before exposing it, and confirm the staff control panel is only reachable after configuration.

| H1: Admin dashboard accessible without authentication (client data exposure) | |
|---|---|
| Score | 7.5 (High) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:N |
| Target | • https://ausecurity.best/dashboard.html<br>• https://ausecurity.best/dashboard<br>• 51.79.166.148:8080 |
| References | https://cwe.mitre.org/data/definitions/306.html |

## Overview

The administrator dashboard is served to unauthenticated visitors and exposes business metrics, revenue figures, and personally identifiable information of clients.

## Details

GET /dashboard (and /dashboard.html) returns HTTP 200 without any authentication challenge. The page hard-codes: aggregate counters (enquiries, active clients, assessments, proposals), a "Recent Enquiries" panel listing roughly five client enquiries with company names, contact-person names, and email addresses, an activity log referencing client engagements, and a year-to-date revenue figure. The same page is served unencrypted over HTTP on port 8080. This is a broken-access-control issue combined with sensitive information disclosure (client PII and business intelligence).

## Recommendation

Enforce server-side authentication and authorization on the dashboard (and its backing data) rather than relying on client-side checks. Remove business/PII data from static HTML and load it via authenticated API calls only. Disable the plain-HTTP service on 8080.

| M1: Admin panel and full site served over plain HTTP on port 8080 | |
|---|---|
| Score | 6.5 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N |
| Target | 51.79.166.148:8080 (ausecurity.best) |
| References | https://cwe.mitre.org/data/definitions/319.html |

## Overview

The same web application (including the admin dashboard and login) is served unencrypted over HTTP on port 8080.

## Details

Port 8080 on 51.79.166.148 serves nginx/1.25.5 returning the identical site content over plain HTTP with no TLS. This includes the login page and the admin dashboard. Credentials and session cookies transmitted via this port are exposed to network eavesdropping.

## Recommendation

Close port 8080 externally or redirect it to HTTPS. Serve the application exclusively over TLS.

| M2: DOM-based cross-site scripting via "name" parameter (success page) | |
|---|---|
| Score | 6.1 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:N |
| Target | https://ausecurity.best/consultation-success.html |
| References | https://cwe.mitre.org/data/definitions/79.html |

## Overview

The consultation-success page reflects the "name" URL parameter into the DOM using innerHTML without sanitization, allowing arbitrary script execution in the victim's browser.

## Details

An inline script reads the "name" query parameter and assigns it to the #user-name element via innerHTML (a classic DOM XSS sink). A crafted URL such as /consultation-success.html?name=<img src=x onerror=...> executes attacker-controlled JavaScript in the page context. This was verified by loading a payload that changed the document title. The /api/contact endpoint further reflects the submitted full_name value into a redirect_url that points at this page, creating a self-XSS-to-URL chain.

## Recommendation

Use textContent (or an equivalent safe API) instead of innerHTML for untrusted values, and URL-encode/sanitize reflected values. Apply a Content-Security-Policy that restricts script sources.

| M3: Missing security response headers | |
|---|---|
| Score | 5.4 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:L/A:N |
| Target | https://ausecurity.best/ (all public pages) |
| References | https://owasp.org/www-project-secure-headers/ |

## Overview

The main website omits several important security headers, weakening protection against clickjacking, MIME sniffing, and connection downgrade.

## Details

Public pages (index, services, about, case-studies, contact, login, dashboard) are served without Strict-Transport-Security (HSTS), Content-Security-Policy (CSP), X-Content-Type-Options, and (on most pages) X-Frame-Options and Referrer-Policy. The login and dashboard pages set X-Frame-Options: DENY, but the marketing pages do not, and no HSTS is sent anywhere, allowing HTTP-based downgrade and MITM.

## Recommendation

Add a consistent set of security headers, including Strict-Transport-Security, Content-Security-Policy, X-Content-Type-Options: nosniff, X-Frame-Options (or CSP frame-ancestors), and Referrer-Policy, and enforce HTTPS site-wide with an HTTP-to-HTTPS redirect.

| M4: WordPress uploads directory listing enabled | |
|---|---|
| Score | 5.3 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| Target | https://blog.ausecurity.best/wp-content/uploads/ |
| References | https://cwe.mitre.org/data/definitions/548.html |

## Overview

Directory listing is enabled on the WordPress uploads directory, exposing its structure.

## Details

GET /wp-content/uploads/ returns an Apache autoindex page ("Index of /wp-content/uploads") showing subdirectories (e.g., 2026/). This leaks the media directory layout to unauthenticated users.

## Recommendation

Disable directory indexing (Options -Indexes) for wp-content and its subdirectories.

| M5: WordPress username enumeration | |
|---|---|
| Score | 5.3 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N |
| Target | https://blog.ausecurity.best/ |
| References | https://cwe.mitre.org/data/definitions/200.html |

## Overview

The WordPress blog discloses the "admin" username through the author-archive redirect.

## Details

Requesting /?author=1 returns a 301 redirect (X-Redirect-By: WordPress) to /index.php/author/admin/, revealing the "admin" login name. This aids targeted attacks against the login form.

## Recommendation

Prevent author enumeration (e.g., disable author archives or neutralize the redirect), enable login rate limiting, and consider renaming the administrator account.

| M6: osTicket session cookie missing HttpOnly flag | |
|---|---|
| Score | 4.3 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:L/I:N/A:N |
| Target | https://ticket.ausecurity.best/ |
| References | https://cwe.mitre.org/data/definitions/1004.html |

## Overview

The osTicket PHPSESSID cookie is set without the HttpOnly attribute.

## Details

The session cookie (PHPSESSID) is issued without the HttpOnly flag, so client-side script could read it if a script-execution vulnerability is present.

## Recommendation

Set the HttpOnly (and Secure, SameSite) attributes on session cookies.

| M7: Self-signed TLS certificate on main site | |
|---|---|
| Score | 4.2 (Medium) |
| Vector string | CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:L/A:N |
| Target | https://ausecurity.best/ |
| References | https://cwe.mitre.org/data/definitions/295.html |

## Overview

The main website presents a self-signed TLS certificate that cannot be validated against a trusted CA, exposing visitors to man-in-the-middle risk and browser trust warnings.

## Details

The certificate for ausecurity.best is self-signed (issuer == subject), has no certificate transparency log entry, and fails OpenSSL verification (error 18, self-signed). The blog and ticket hosts use their own certificates. Visitors must bypass browser warnings to use the site, and traffic cannot be verified as authentic.

## Recommendation

Deploy a certificate from a trusted public CA (e.g., Let's Encrypt) and enable automatic renewal. Consider a wildcard/SAN certificate covering all subdomains.

| I1: Contact API returns unhandled server error for unexpected routing field | |
|---|---|
| Score | 0.0 (Info) |
| Vector string | N/A |
| Target | https://ausecurity.best/api/contact |
| References | https://cwe.mitre.org/data/definitions/20.html |

## Overview

Submitting an unexpected value in the "h" routing field causes an unhandled HTTP 500 error.

## Details

The contact endpoint accepts a client-supplied "h" field. Sending an unexpected value (e.g., "evil.example.com") returns HTTP 500 "Internal Server Error" with a generic body, indicating insufficient input validation and error handling (and confirming the field is processed server-side). No stack trace was leaked.

## Recommendation

Validate and restrict the "h" field to an allowlist of known hostnames and return a structured 4xx response for invalid values.

| I2: Technology and version information disclosure | |
|---|---|
| Score | 0.0 (Info) |
| Vector string | N/A |
| Target | • ausecurity.best<br>• blog.ausecurity.best<br>• ticket.ausecurity.best |
| References | https://cwe.mitre.org/data/definitions/200.html |

## Overview

Multiple components disclose their exact software versions and framework fingerprints.

## Details

Observed disclosures include nginx/1.22.1 and nginx/1.25.5 (also visible in the 404 page footer, indicating a reverse proxy), PHP/8.2.33 (X-Powered-By on ticket), Apache/2.4.68 (Debian), osTicket v1.18.4, the WordPress version, and FastAPI/Starlette-style JSON error envelopes on the API. These fingerprints help attackers select known exploits.

## Recommendation

Suppress version banners (server_tokens off, expose_php off, remove X-Powered-By), and return generic error responses for the API.

| I3: WordPress XML-RPC enabled | |
|---|---|
| Score | 0.0 (Info) |
| Vector string | N/A |
| Target | https://blog.ausecurity.best/xmlrpc.php |
| References | https://cwe.mitre.org/data/definitions/799.html |

## Overview

The WordPress XML-RPC endpoint is enabled and reachable.

## Details

GET /xmlrpc.php returns "XML-RPC server accepts POST requests only" (405), confirming the endpoint is active. XML-RPC can be abused for amplified credential attacks and pingback SSRF when not required.

## Recommendation

Disable XML-RPC (plugin or web-server rule) unless it is explicitly required.

| I4: WordPress version and readme disclosure | |
|---|---|
| Score | 0.0 (Info) |
| Vector string | N/A |
| Target | https://blog.ausecurity.best/ |
| References | https://cwe.mitre.org/data/definitions/200.html |

## Overview

The WordPress installation discloses its version string and leaves readme.html accessible.

## Details

The site's generator meta tag and asset query strings advertise the WordPress version, and /readme.html is publicly reachable. The Apache server banner (Apache/2.4.68) is also disclosed. This information assists attackers in targeting version-specific issues.

## Recommendation

Remove readme.html and license/readme files, suppress the generator/version meta, and reduce server banner verbosity.

# 5 Disclaimer

The purpose of this research project is to help evaluating the seamlessness, effectiveness and cost-benefit ratio of autonomously performing vulnerabilty assessment using agentic AI. I do not take any responsibility upon any misuse or abuse of such tool where it can face significant legal actions.

# A Appendix

## A.1 Static Appendix Section

## A.2 Assessment Methodology

The assessment combined passive and light-active enumeration (DNS, WHOIS, and certificate analysis), fast port discovery followed by targeted service and version detection, manual web application testing (authentication, access control, input validation, cross-site scripting, and misconfiguration), and narrow-scope validation of material findings. No destructive or intrusive techniques were used.

## A.3 Coverage Summary

All three in-scope hosts were enumerated and tested across their open ports (main site: 22/80/443/8080; blog: 22/80/443; ticket: 22/443). The main site's API endpoints (/api/auth/login, /api/auth/me, /api/auth/logout, /api/contact, /api/health), the WordPress blog, and the osTicket installer were assessed.

## A.4 Limitations

No brute-force, password-spraying, or credential-stuffing testing was performed, nor any social engineering, phishing, lateral movement, or stealth/evasion testing. Shodan and certificate-transparency logs contained no data for these hosts (the certificates are self-signed). Email (MX/SPF/DMARC) was not configured and was outside scope. Database and session internals were not directly accessed.